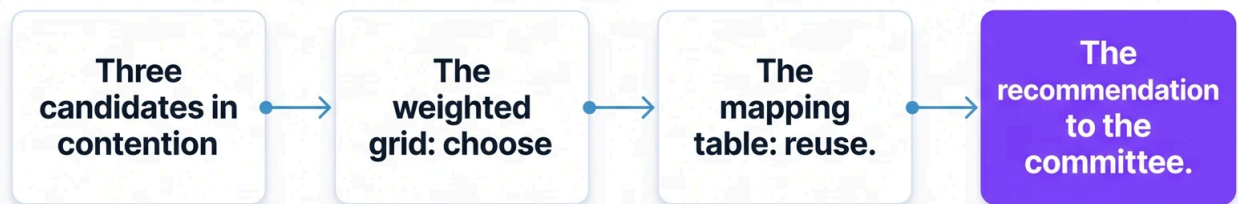


Selecting a framework and mapping tables

✓ From the overview to the decision



Session objectives

By the end of this tutorial:

- **Build** a grid of selection criteria for a framework, weighted and defensible before senior management
- **Explain** what a mapping table between frameworks is, what it contains and what it does not prove
- **Establish** a reasoned mapping between real requirements (NIS 2, ISO/IEC 27001, hygiene guide) while qualifying the relationship
- **Formulate** a framework recommendation for the MERIDIAN group, in ten lines that hold up before an objective Committee



Prerequisites

- The overview from this morning's lecture: the four families of frameworks and the regulatory map of the MERIDIAN subsidiaries.
- The NIS 2 applicability characterization from the "CISO's briefing": essential, important or out of scope, subsidiary by subsidiary.
- The session 2 mapping: it will serve as an asset, in the literal sense, in exercise 2.

✓ What to set down before getting hands-on

A quarter of an hour of framing, no more: two notions specific to this tutorial, which this morning's lecture deliberately left aside.

Selection criteria, first.

The problem. This morning, three logics each argued for a different framework: the obligation for the ReCyF, client-facing proof for ISO/IEC 27001, the immediate first steps for the guides. Yet only one can be kept. An organization that chooses by feel actually chooses according to its executive's most recent conversation.

The definition. A selection criterion is an attribute of the framework, observable and comparable, evaluated BEFORE deciding. Six are enough for this tutorial:

- is it mandatory for us, or will it become so?
- does it cover our actual scope, technical and organizational?
- does it allow defensible proof, certification or attestation?
- does it exist in French, and is it maintained?
- can our tooling and our teams carry it?
- what does it cost, in licences as in effort?

The mechanics, in four moves. List the criteria. Weight them according to the organization's context. Score each candidate. And above all WRITE the justification for each score: the justification is what will be challenged, never the number.

The limit. A weighted grid does not compute the right answer, it makes the deliberation transparent. If its result offends common sense, it is the weighting that gets re-examined, not common sense.

The mapping table next, also known as a security mapping.

The problem. Frameworks overlap. The inventory of systems is required by NIS 2, by Annex A of ISO/IEC 27001 and by the hygiene guide, each in its own words. An organization treating each text in isolation would do the inventory three times, with three diverging spreadsheets.

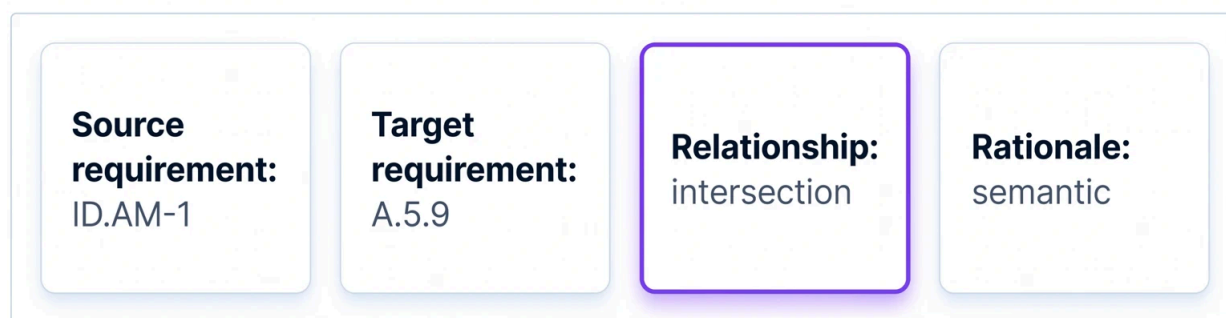
The definition. A mapping table sets side by side, line by line, the requirements of a SOURCE framework and those of a TARGET framework. It serves two purposes: reusing what is already done, and spotting what is missing.

Here is a real line, taken from the mapping set running from NIST CSF 1.1 to ISO 27001, delivered with the group's GRC tool and containing 180 of them:

- source requirement: ID.AM-1, asset management from the IDENTIFY function, seen in this morning's lecture;
- target requirement: A.5.9;
- relationship: "intersect";
- justification: "semantic".

Two of those four fields teach the essentials. The relationship first. In this whole mapping set, NOT ONE line declares two requirements equivalent: all say "intersection", that is, a partial overlap. The justification next. "Semantic" means the match is a judgement of meaning, not a legal equivalence. ANSSI says the same at the top of its own framework comparison tool, made available « à titre purement informatif et indicatif », purely for information and guidance.

The limit, and this is the sentence to keep. A mapping helps to understand and to reuse. It NEVER transfers compliance. Being compliant with the source does not make one compliant with the target: it gives a head start, which remains to be proven in the target's own terms.



Everything is now in place: a grid to choose, a table to reuse. The three exercises walk through exactly this chain.

Exercise 1: the MERIDIAN group's selection grid

The situation is Thursday's: the Executive Committee expects from the Group CISO a proposal for a single framework to serve as the backbone of security for the four subsidiaries. Three candidates are on the table, drawn from this morning's overview: ISO/IEC 27001:2022, the ReCyF, and ANSSI's Guide d'hygiène informatique.

The expected output: a complete selection grid, on the model below, with its weightings, its scores from 0 to 3 and a written one-line justification per score.

Criterion	Weighting (to be set)	ISO/IEC 27001:2022	ReCyF	Hygiene guide
Mandatory nature, current or upcoming	...	...	...	...
Coverage of the group's scope	...	...	...	...
Proof defensible before third parties	...	...	...	...
Maturity and stability of the text	...	...	...	...
Tooling and implementation workload	...	...	...	...

1. **Complete** the grid: set the weightings and justify them by the MERIDIAN context established since session 1 (hint: how much does the fact that Santé will very probably be an essential entity weigh? how much do Territoires' thirty or so client local authorities weigh?).
2. **Identify** the criterion which, in the group's context, would deserve a right of veto rather than a weighting, and explain why a weighted average can mask a disqualifying criterion.
3. **Analyse** the sensitivity of the result: which weighting would have to change, and by how much, for the ranking to flip between the top two candidates? What does this fragility, or this robustness, teach about the solidity of the recommendation?

Suggested time: 15 minutes. Work in pencil: the grid will be taken up as is in the business case note at the end of the day.

Exercise 2: three requirements, three mappings

Here are three real requirements, copied from their official texts. The task: for each one, say what corresponds to it in the other two columns of the landscape, and qualify the relationship.

Requirement A, published by ANSSI in the NIS 2 requirement set of its comparison tool, reference 1.1-EI/EE: « L'entité liste l'ensemble de ses activités et services, y compris les activités et services qui ne correspondent pas aux critères pour lesquels l'entité constitue une entité importante ou essentielle » (the entity lists all of its activities and services, including the activities and services that do not match the criteria for which the entity constitutes an important or essential entity). For each entry in this list, the entity identifies an owner and lists the information systems supporting it.

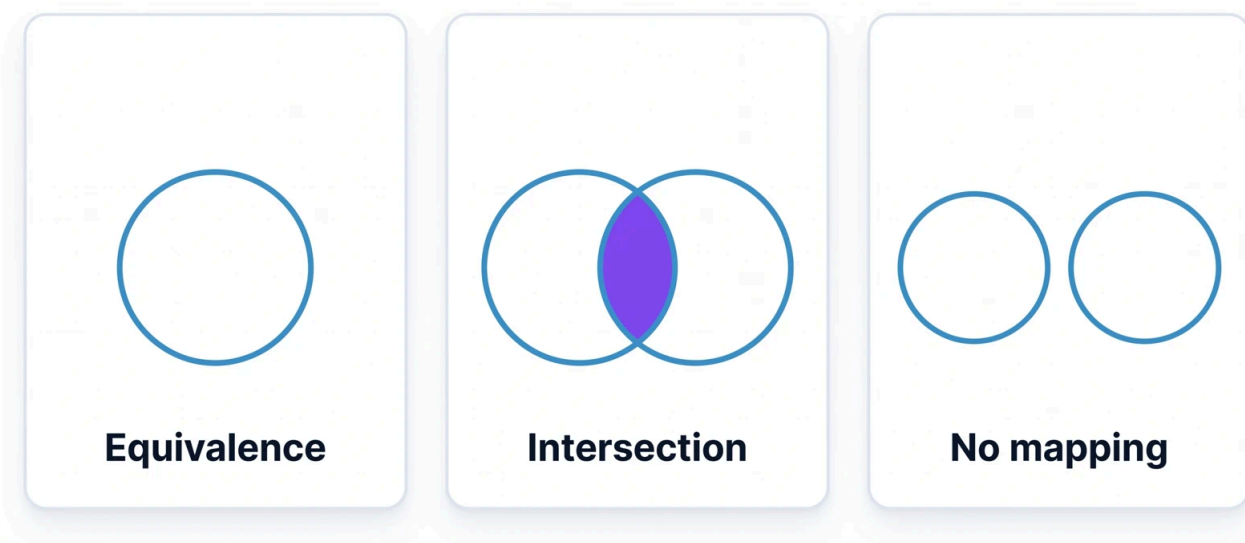
Requirement B, security objective 2 of the ReCyF: the implementation of a digital security governance framework comprising an organization, roles and responsibilities, compliance management processes, and an information systems security policy.

Requirement C, measure 4 of the hygiene guide, known since session 2: identify the most sensitive information and servers and maintain a network diagram.

Instructions, for each requirement:

1. **Designate** the corresponding element on the ISO/IEC 27001:2022 side: the block (clauses 4 to 10, or Annex A) and, if it is Annex A, the most relevant theme among the four seen this morning (hint: ask whether the requirement is about organizing the steering or deploying a control).
2. **Qualify** the relationship with one of the three verdicts: equivalence, intersection, no correspondence; then justify in one sentence what the source requires that the target does not, or the reverse.
3. **Spot** what the MERIDIAN group ALREADY has for the subsidiary under review that satisfies all or part of the source requirement, citing precisely the deliverable from sessions 1 or 2 concerned.
4. **Conclude** in two sentences: what does this exercise say about the idea "we will be NIS 2 compliant since we apply ISO 27001"? Lean on one of the three cases to show it.

Suggested time: 20 minutes. The trap of the exercise is known in advance: the temptation to tick "equivalence" wherever the subjects look alike. Reread the anatomy from the framing: the relationship is judged on what the texts REQUIRE, not on what they talk about.



✓ Exercise 3: the ten-line recommendation

Last move, the one that directly prepares the end-of-day lab: turning the grid and the mappings into a recommendation.

Draft a paragraph of at most ten lines, addressed to the Executive Committee, which: names the recommended backbone framework for the group; gives the two decisive arguments drawn from the grid; states explicitly what this choice does NOT cover and how the rest will be handled; and ends with the decision requested from the committee. Realism constraint: the paragraph must remain true whether the Résilience law is promulgated in three months or in eighteen.

Suggested time: 10 minutes. It is an assumed rough draft: the complete, reasoned version will be the business case note of the final lab.



Answer keys and assessment criteria – cliquer pour révéler

+10 XP

Leçon terminée